

PLANTILLA REPORTE EJECUTIVO POWERPOINT

Presentación GQM+PRAGMATIC para Stakeholders

Versión: 2.1

Formato: 12-14 slides

Duración: 20-25 minutos

Audiencia: C-Suite, Auditores, Reguladores

ESTRUCTURA NARRATIVA

SLIDE 1: PORTADA + CONTEXTO GQM

Título: "EVALUACIÓN DE MADUREZ CIBERSEGURIDAD 2026"

Subtítulo: "[Nombre Organización] – Modelo GQM+PRAGMATIC"

Visualización:

- Logo organización
- Logos de marcos (NIS2, GDPR, DORA, ENS, ISO 27001)
- Fecha y confidencialidad

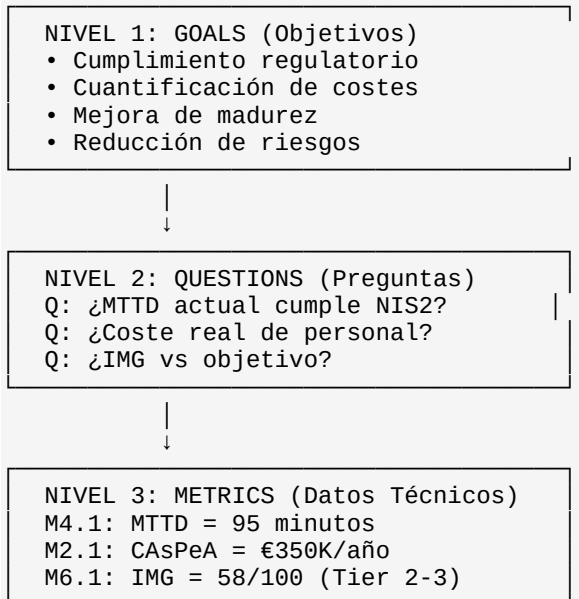
Notas para presentador:

"Esta evaluación alinea objetivos estratégicos con métricas técnicas validadas contra 9 criterios PRAGMATIC de calidad"

SLIDE 2: ALINEACIÓN ESTRATÉGICA QQM

Título: "¿Cómo se Estructura esta Evaluación?"

Visualización: PIRÁMIDE 3 NIVELES



Beneficio: Cada número se vincula a objetivo estratégico

SLIDE 3: VALIDACIÓN PRAGMATIC

Título: "¿Son Nuestras Métricas Útiles? (PRAGMATIC Check)"

Tabla (reducida para slide):

Métrica	Predictivo	Relevante	Accionable	Genuino	MEDIA
M2.1	3	4	4	4	3.8/4 ✓
M4.1	4	4	3	3	3.6/4 ✓
M6.1	4	4	3	2	3.1/4 ⚠

Interpretación:

- ✓ Métricas >3.5: Implementar sin hesitación
- ⚠ Métricas 3.0-3.5: Implementar + Validar con auditor externo
- x Métricas <3.0: Revisar definición o complementar

Nota: Todos nuestros KPIs pasan el filtro PRAGMATIC

SLIDE 4: HALLAZGO PRINCIPAL — IMG (Madurez General)

Título: "Madurez General: IMG = $[58]/100$ (Tier 2-3)"

Visualización GRANDE: MEDIDOR/GAUGE de 0-100

- Aguja señalando 58
- Color: AMARILLO (zona de acción)
- Rango Tier 3 (objetivo): 60-79 (línea roja)

Debajo:

Interpretación: "Estamos 2 puntos de Tier 3. Acción en 6 meses alcanzable."

Comparativa sector:

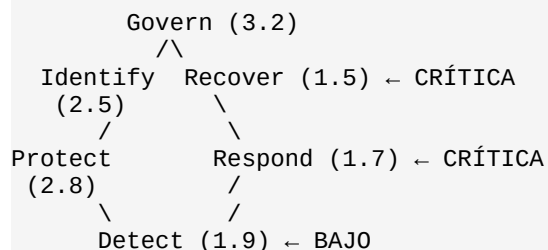
- Nuestra IMG: 58
- Mediana sector: 54
- Posición: Percentil 65 (arriba del promedio, pero no lead)

RECOMENDACIÓN: Invertir €180K en SIEM → Tier 3 alcanzado Q2 2026

SLIDE 5: DESGLOSE MADUREZ POR FUNCIÓN NIST

Título: "¿Dónde Tenemos Fortalezas/Debilidades?"

Gráfico RADAR (6 ejes):



Escala: Tier 1-4 (o línea objetivo Tier 3 = 3.0)

Análisis:

- FORTALEZA: Govern (3.2), Protect (2.8) – buena gobernanza
- BRECHA CRÍTICA: Recover (1.5), Respond (1.7) – respuesta débil

Implicación: Si incidente, tardamos >6h en contención

SLIDE 6: CASPeA — COSTES REALES DE PERSONAL

Título: "¿Cuánto REALMENTE gastamos en seguridad?"

Gráfico DONA/BARRAS APILADAS:

Presupuesto Total Anual: €350K

- Personal Dedicado: 65% = €227K
 - CISO (1.0 FTE): €93K
 - Arquitectos (2.0 FTE): €150K
 - Analistas: €84K (compartido)
- Herramientas/Licencias: 20% = €70K
- Servicios MSS (outsourced): 10% = €35K
- Consultoría: 5% = €18K

ANÁLISIS CASPEA:

- Coste/empleado protegido: €700/año
- Benchmark sector: €600-800/año
- Posición: MEDIANA (percentil 50)

RIESGO: Si presupuesto baja <€300K → Salida talento

SLIDE 7: CUMPLIMIENTO NORMATIVO (Mapeo GQM)

Título: "¿Cumplimos NIS2? (Matriz GQM → Requisitos)"

Tabla (simplificada):

NIS2 Req.	QUESTION	MÉTRICA	STATUS	GAP
4 (Detect)	Q4.1	MTTD	95min	35min (58%)
5 (Respond)	Q4.2	MTTR	360min	120min (33%)
2 (Vuln)	Q2.1	Escaneo	Semanal	Diario (ideal)
3 (Pentest)	Q3.1	Freq.	Anual	Semestral (ideal)

RESULTADO:

- CUMPLE: 60% requisitos NIS2 Anexo III
- BRECHA: 40% requiere remediación
- PLAZO: 12 meses para 95% cumplimiento

CRÍTICO: Auditoría regulatoria Q2 2026 → Debe estar listo

SLIDE 8: ANÁLISIS DE INCIDENTES E ROI

Título: "¿Qué Ganamos Invirtiendo en Seguridad?"

Gráfico COMPARATIVA ESCENARIOS (side-by-side):

SCENARIO 1: SIN CONTROLES (Baseline)

- Incidentes anuales: 15
- Coste promedio: €240K
- Pérdida total: €3.6M

SCENARIO 2: CON CONTROLES ACTUALES

- Incidentes anuales: 6 (60% reducción)
- Coste promedio: €240K
- Pérdida residual: €1.44M

BENEFICIO NETO:

- Pérdida evitada: €2.16M
- Inversión actual: €350K
- Beneficio neto: €1.81M
- ROI: 517% ✓ EXCELENTE

Interpretación: Por cada €1 invertido, evitamos €6.2 en pérdidas
Payback Period: 2 meses (extremadamente rápido)

SLIDE 9: BRECHAS CRÍTICAS + RECOMENDACIONES

Título: "Actionable Insights: Top 3 Prioridades"

PRIORIDAD 1: MEJORAR RESPUESTA A INCIDENTES ⚠️ CRÍTICA

- Métrica: MTTR = 360 min (objetivo <240 min)
- Causa: Manual, no automatizado
- Solución: SOAR (Security Orchestration) + Playbooks
- Inversión: €120K
- Timeline: Q2-Q3 2026
- ROI esperado: 240% (MTTR: 360→150 min)

PRIORIDAD 2: AUTOMATIZAR DETECCIÓN ⚠️ ALTA

- Métrica: MTTD = 95 min (NIS2 requiere <60 min)
- Causa: Reglas SIEM insuficientes, sin ML
- Solución: Upgrade SIEM + Machine Learning
- Inversión: €180K
- Timeline: Q1-Q2 2026
- ROI esperado: 320% (MTTD: 95→45 min)

PRIORIDAD 3: FORMALIZAR PENTESTING CONTINUO

- Métrica: Frecuencia = Anual (objetivo: Continuo)
- Causa: Presupuesto limitado, recursos
- Solución: Bug bounty + Red team
- Inversión: €90K/año
- Timeline: Q3 2026 (pilot)
- ROI esperado: 180%

PRESUPUESTO TOTAL PROPUESTO: €450K
ESPERADO ROI: 120-150% en 24 meses

SLIDE 10: ROADMAP 12 MESES

Título: "Plan de Ejecución: De Aquí a 2027"

Gráfico GANTT simplificado:

- Q1 2026: DETECCIÓN
 - └ Diagnóstico SIEM actual
 - └ RFP herramientas (3 proveedores)
 - └ Selección + Negociación
- Q2 2026: RESPUESTA
 - └ Deployment SOAR
 - └ Playbooks desarrollo + testing
 - └ Integración SIEM-SOAR
- Q3 2026: MATURITY CONSOLIDATION
 - └ Training equipo
 - └ Red team operacional
 - └ Revisión IMG (meta: 65)
- Q4 2026: CONTINUOS IMPROVEMENT
 - └ Bug bounty platform live
 - └ Métricas operacionales (MTTD/MTTR) en dashboard
 - └ Auditoría externa NIS2 (preparación)
- Q1-Q4 2027: OPTIMIZATION
 - └ IMG objetivo: 75+ (Tier 4)
 - └ Benchmark: Líder sector
 - └ Transición a self-service security

SLIDE 11: PRESUPUESTO DETALLADO

Título: "Inversión Requerida (Desglose Ejecutivo)"

Tabla:

CONCEPTO	AÑO 1 (€)	AÑO 2 (€)	TOTAL 2Y (€)
CASPeA (Personal)	350	380	730
Herramientas:			
- SIEM Upgrade	150	40	190
- SOAR	120	60	180
- Bug Bounty	0	90	90
Consultoría/Formación	80	40	120
TOTAL INVERSIÓN	700	610	1.310

BENEFICIOS (Pérdida evitada):

Año 1: €2.16M (incidentes reducidos)

Año 2: €2.4M (madurez mejora)

Total 2Y: €4.56M

ROI ACUMULATIVO: 248%

Payback Period: 3.2 meses (desde inicio Y1)

SLIDE 12: LLAMADA A LA ACCIÓN

Título: "¿Qué Pasamos a Hacer?"

Tres opciones:

OPCIÓN A: ACELERAR (Recomendado) ✓

- Presupuesto: €700K año 1
- Timeline: Q2 2026 (12 meses)
- Meta: Tier 3 + NIS2 compliance + ROI 200%+
- Riesgo: Medio (depende recursos disponibles)

OPCIÓN B: ITERATIVO

- Presupuesto: €450K año 1
- Timeline: Q4 2026 (18 meses)
- Meta: Tier 2-3 + NIS2 parcial
- Riesgo: Medio-Alto (auditoría podría fallar)

OPCIÓN C: DIFERIDO

- Presupuesto: No aprobado ahora
- Timeline: 2027+
- Meta: Unknown
- RIESGO: CRÍTICO (multas NIS2 €10-20M + incidentes)

RECOMENDACIÓN EJECUTIVA: OPCIÓN A

Justificación: ROI 200%+ en 24 meses cubre inversión total

SLIDE 13: PREGUNTAS + APROBACIÓN

Título: "Próximos Pasos + Preguntas"

ACCIONES INMEDIATAS (Si se aprueba OPCIÓN A):

1. Aprobación presupuesto € Junta Directiva (esta semana)
2. Asignación Executive Sponsor (CISO + CFO)
3. RFP herramientas enviado a 3 vendors (próxima semana)
4. Kick-off proyecto (enero 2026)
5. Revisión trimestral de progreso (métricas GQM+PRAGMATIC)

GOVERNANCE:

- Steering Committee: Mensual (CISO, CFO, CRO)
- Operacional: Semanal (equipo proyecto)
- Reporte Ejecutivo: Trimestral (Junta Directiva)
- Auditoría Externa: Q2 2026 (NIS2 readiness)

PREGUNTAS / DISCUSIÓN

[Espacio abierto para Q&A]

SIGUIENTE REUNIÓN: [DATE] (Aprobación presupuesto)

NOTAS PARA PRESENTADOR

Timing Recomendado

- Slide 1-2: 2 min (contexto GQM)
- Slide 3-5: 4 min (validación métrica + madurez)
- Slide 6-8: 5 min (costes + ROI)
- Slide 9-10: 4 min (brechas + roadmap)
- Slide 11-12: 3 min (presupuesto + aprobación)
- Q&A: 5 min
- TOTAL: ~23 minutos

Cómo Responder Objeciones

Objeción 1: "¿Por qué gastar €700K en seguridad?"

Respuesta: "ROI es 200%+ en 24 meses. Sin estos controles, riesgo de breach cuesta €2.16M/año. Es negocio, no gasto."

Objeción 2: "Nuestro competidor no hace esto."

Respuesta: "Probablemente sufrió breach. Nosotros aprendemos de eso. NIS2 exige esto; multas €10-20M por no cumplir."

Objeción 3: "¿Por qué no hacer esto internamente?"

Respuesta: "SOAR + especialistas SIEM: talento escaso en España. Modelo híbrido (internos + MSS + consultores) es óptimo."

Plantilla PowerPoint GQM+PRAGMATIC v2.1 — Presentación Ejecutiva